a2f930c7-00d1-40b1-828f-7a9ea308b9

<prev_user>

<request>

You have been given comments on the previous commits you made in the repository.

You are working on an issue in the 'trykimu/videoeditor' repository.

<repository_context>
I've cloned the repository in the directory /home/runner/work/videoeditor/videoeditor (not in /tmp/inputs). Always use absolute paths when referring to files in the repository.
</repository_context>

<current_datetime>2026-03-09T06:12:03.056Z</current_datetime>

Consider the following problem statement:

<problem_statement>

This section includes details on the pull request with code changes you have already submitted to fix the problem above.

<pr_title>
to a glorious future
</pr_title>

<pr_description>
main should be main
</pr_description>

Comments on the PR (you are @copilot in this section)

<comments>

<pr_comments>

<comment_new>
<comment_id>4021392529</comment_id>
<author>@sr2echa</author>

```
@copilot
</comment_new>
```

</pr_comments>

</comments>

The last **11** git commits in this branch are the changes you have made so far. Use those as your change commit history.
</problem_statement>

Analyze and determine if action or explanation is needed
<rules_for_making_changes>
* Start by fully understanding <problem_statement> and the <comments> before making any changes. You will only address the <comment_new> comments. Reply to new comments as you address them. Ignore comments that are not actionable or directed at you.
* For each new comment, determine:
    - If it a request for changes, a question on the code or a suggestion.
    - Is it addressed to you or someone else, e.g. "Hey @username, ..." or "@username can you ...".
    - Is it a general comment or praise.
* If there are no comments you need to address or reply to, you can stop now without exploring or explaining yourself.
* If the user's ask is not clear, you can reply to the comment and ask for clarification.
* If an action or explanation is needed, follow the steps below.
</rules_for_making_changes>

<prompt>

@copilot

<prev_assistant>

The comment `@copilot` from @sr2echa contains no actionable request, question, or feedback — it's just a mention with no accompanying text. There's nothing specific to address or reply to here.

<current>

<request>

You have been given comments on the previous commits you made in the repository.

You are working on an issue in the 'trykimu/videoeditor' repository.

<repository_context>
I've cloned the repository in the directory /home/runner/work/videoeditor/videoeditor (not in /tmp/inputs). Always use absolute paths when referring to files in the repository.
</repository_context>

<current_datetime>2026-03-09T06:13:14.986Z</current_datetime>

Consider the following problem statement:

<problem_statement>

This section includes details on the pull request with code changes you have already submitted to fix the problem above.

<pr_title>
Merge canary into main: path security, Zod validation, AI enhancements, infra updates
</pr_title>

<pr_description>
Brings `canary` up to date with accumulated feature and hardening work, making it ready to merge into `main`.

Changes

- **Path traversal security** (`app/utils/path-security.ts`): New `safeResolvePath` / `safeResolveOutPath` / `isValidFilename` utilities; applied across asset and project API routes and video render module to prevent directory escape attacks.

- **Zod validation layer** (`app/schemas/`): Centralized schema definitions (`timeline`, `llm`, `auth`, `chat`, `media`, `assets`, `projects`, `params`) introduced and wired into API routes and components — replacing ad-hoc runtime checks.

- **AI / ChatBox improvements** (`app/components/chat/

ChatBox.tsx`, `app/utils/llm-handler.ts`, `backend/main.py`): Context menu actions, richer tool catalog (`backend/tools_registry.py`), smart time-field normalization (`_normalize_time_fields_from_text`, `_to_seconds`) to handle freeform time expressions from the model.

- **Media bin & timeline refactor** (`app/hooks/useMediaBin.ts`, `app/hooks/useTimeline.ts`, `app/components/timeline/MediaBin.tsx`): Streamlined deletion logic; de-duplicated state management.

- **Left panel rebuild** (`app/components/editor/LeftPanel.tsx`): Restyled panel bar.

- **Infra / config** (`docker-compose.dev.yml`, `nginx.conf`, `.env.example`, `Dockerfile.frontend`): Added dev compose file, corrected frontend port routing in nginx, aligned env vars for new deployment topology.

- **Dependency bumps**: `react-router` → 7.12.0; added `zod` to frontend; backend Poetry lock updated.
</pr_description>

<stacked_pr_context>
The pull request you are currently working on is a stacked pull request on top of another pull request. The base branch is `ai`, not the default branch `main`. If you are asked to fix CI, build, test, or workflow failures, check the GitHub Actions workflow runs for the original branch (`ai`) first. If you don't find relevant failures there, then check your branch (`copilot/sub-pr-152`).
</stacked_pr_context>

Comments on the PR (you are @copilot in this section)

<comments>

<pr_comments>

<comment_new>
<comment_id>4021396399</comment_id>
<author>@sr2echa</author>
@copilot+claude-sonnet-4.6 Fix these issues:

Please resolve the following Polynomial ReDoS vulnerabilities identified by CodeQL in backend/main.py. For each issue, rewrite the regex to be "linear" or "possessive"

to prevent catastrophic backtracking.

Issue 1: Duration Unit Parsing
File: backend/main.py

Location: Inside the _to_seconds function (the re.finditer call).

Problem: The group (?P   \d+(?:\.\d+)?)\s* combined with the long list of optional units can be exploited if a user provides a very long string of numbers and spaces without a valid unit terminator.

Fix Required: Simplify the numeric matching and ensure the unit boundaries are strict.

Issue 2: "From...To..." Extraction
File: backend/main.py

Location: m = re.search(r"from\s+([^\s]+(?:\s*[a-z]+)?) \s+to\s+([^\s]+(?:\s*[a-z]+)?)", text)

Problem: The nested optional groups ([^\s]+(?:\s*[a-z]+)?) are the culprit. When the engine fails to find a match, it tries every possible permutation of spaces and letters, leading to exponential complexity (specifically triggered by strings like "from !" followed by many "aa").

Fix Required: Refactor to avoid nested quantifiers. Use a simpler non-whitespace match or a non-backtracking approach.

Issue 3: "Long" Duration Parsing
File: backend/main.py

Location: m4 = re.search(r"(?:to\s+)?([^\s]+(?:\s*[a-z]+)?) \s+long", text)

Problem: Similar to Issue 2, the ([^\s]+(?:\s*[a-z]+)?) pattern is unstable. CodeQL notes it fails on strings with many repetitions of !.

Fix Required: Replace the capture group with a more restrictive pattern that doesn't "loop inside a loop."

Issue 4: "Set to/Make it" Parsing
File: backend/main.py

```
Location: m5 = re.search(r"(?:set\s+(?:it\s+)?to|make\s+
(?:it\s+)?)\s+([^\s]+(?:\s*[a-z]+)?)", text)

Problem: The combination of multiple optional words (it, to)
followed by the same problematic ([^\s]+(?:\s*[a-z]+)?)
group. This is vulnerable to "ambiguous matching" where the
engine gets lost in the spaces.

Fix Required: Flatten the regex and use atomic grouping or
simpler delimiters.
</comment_new>

</pr_comments>

</comments>

----
The last **1** git commits in this branch are the changes you
have made so far. Use those as your change commit history.
</problem_statement>

Analyze and determine if action or explanation is needed
<rules_for_making_changes>
* Start by fully understanding <problem_statement> and the
<comments> before making any changes. You will only address the
<comment_new> comments. Reply to new comments as you address them.
Ignore comments that are not actionable or directed at you.
* For each new comment, determine:
    - If it a request for changes, a question on the code or a
suggestion.
    - Is it addressed to you or someone else, e.g. "Hey
@username, ..." or "@username can you ...".
    - Is it a general comment or praise.
* If there are no comments you need to address or reply to, you can
stop now without exploring or explaining yourself.
* If the user's ask is not clear, you can reply to the comment and
ask for clarification.
* If an action or explanation is needed, follow the steps below.
</rules_for_making_changes>

A **CI/Build Failure** has been mentioned in the problem statement,
```

```
make sure to follow your instructions for addressing CI/Build
Failures.
```